

Debugging Issues in the Removals System

Mindaugas Taujanskas

I. CREATING A BUSINESS AS A CUSTOMER

During the creation of tests for the business creation logic, a bug was discovered regarding the permissibility of customers creating business resources, contrary to the business logic that indicates only service providers may register businesses. The test case is as follows:

```
def test_appropriate_role_permission(
    db_guest_cursor,
    with_valid_user
) -> None:
    _, session = with_valid_user("customer")
    fetch_result = db.proc_create_business(
        session.data.token,
        business_name="Sample business name",
        vat_no=gen_rand_alnum(length=11),
        crn_no=gen_rand_alnum(length=8),
        utr_no=gen_rand_alnum(length=10),
        num_employees=2
    )
    assert not fetch_result.success
```

The case fails on `assert not fetch_result.success`, indicating that the database registered the business resource despite the registering user being a customer. To ensure the database handles this validation, check the procedural definition for the corresponding function:

```
CREATE FUNCTION create_business(
    p_token TEXT,
    ...
)
RETURNS result_t AS $$
DECLARE
    user_session JSON;
    stored_business_id INTEGER;
BEGIN
    user_session := decode_token(p_token);

    IF user_session IS NULL THEN
        RETURN make_error_result(
            'INVALID_SESSION',
            'Invalid session token'
        );
    ELSIF user_session->>'user_role' <> 'service-
        provider' THEN
        RETURN make_error_result(
            'INSUFFICIENT_PERMISSIONS',
            'Invalid role for creating business'
        );
    END IF;

    ...

    RETURN make_success_result();
END;
$$ LANGUAGE plpgsql SECURITY DEFINER;
```

As read, this appears to appropriately check the session data for the user role and is thus non-problematic, but upon further evaluation `user_session->>'user_role'` contains a subtle typo, and must be `user_session->>'role'`, as defined by the registration procedures:

```
token := sign(
    json_build_object(
        'user_id', new_user_id,
        'email', p_email,
        'role', p_user_role -- <<< HERE
    ),
    utils.get_app_config_value('jwt_secret'),
    'HS256'
);
```

After correcting the typo, the test passes, meaning our business logic is correctly implemented at the database-level.